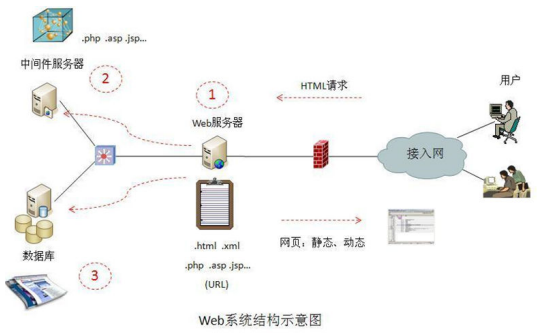
第5章 网络安全
----Web安全

Web系统结构示意图



Web系统结构示意图

Web系统的安全性参差不齐……

- 复杂应用系统代码量大、开发人员多、难免出现疏忽；
- 系统屡次升级、人员频繁变更，导致代码不一致；
- 历史遗留系统、试运行系统等多个Web系统共同运行于同一台服务器上；
- 开发人员未经过安全编码培训；
- 定制开发系统的测试程度不如标准的产品；
- ……

相对安全性而言，开发人员更注重系统功能！

Web攻击面---HTTP Request

```
POST /thepage.jsp?var1=page1.html HTTP/1.1
Accept: */*
Referer: http://www.myweb.com/index.html
Accept-Language: en-us,de;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-url-encoded
Content-Lenght: 59
User-Agent: Mozilla/4.0
Host: www.myweb.com
Connection: Keep-Alive
Cookie: JSESSIONID=0000dlTLGLqhz1dKkPEtpoYqbN2

uid=fred&password=secret&pagestyle=default.css&action=login
```

黑客实际利用的输入点

直接可在浏览器中利用的输入

所有输入点

访问资源名称
GET与POST参数
Referer与User Agent
HTTP 方法
Cookie

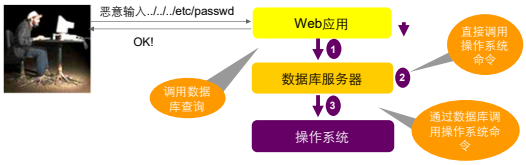
更多输入点

Ajax
Web Service
Flash客户端
Java Applet

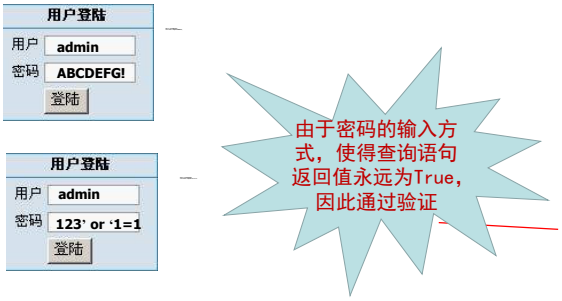
Web攻击

SQL注入

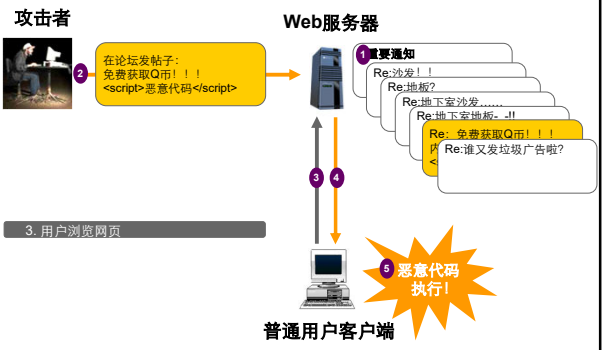
- 目标：借Web应用的“刀”来攻击服务器端的数据库或操作系统。



SQL注入简单示例



跨站脚本攻击（XSS - Cross Site Script）

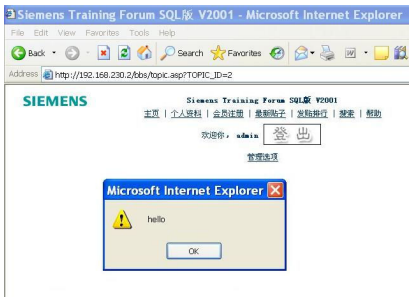


存储型XSS攻击案例

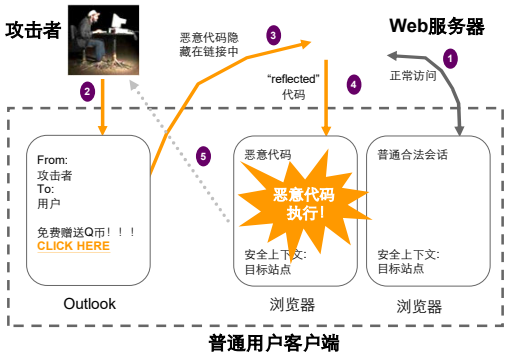
- Step 1：以test用户登录培训论坛发表新帖子，内容如下：<script>alert('hello')</script>

存储型XSS攻击案例（续）

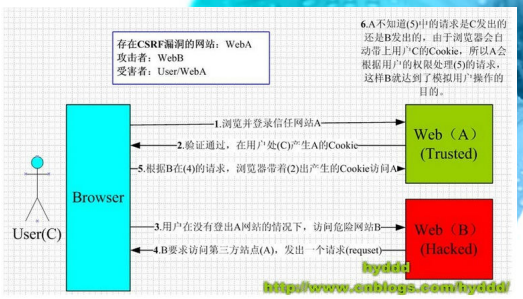
- Step 2：以admin用户登录培训论坛浏览刚才那个新帖子。



反射型XSS - 攻击简介（Reflected XSS）



跨站点请求伪造CSFR（Cross-Site Request Forgery）



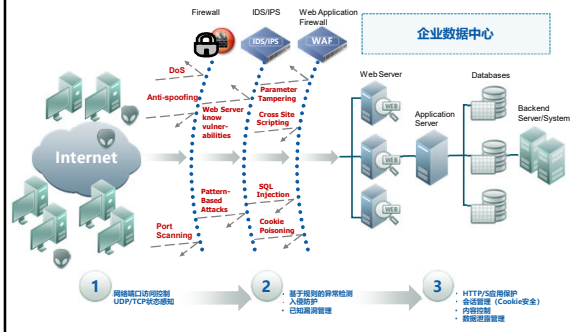
OWASP TOP10

No.	漏洞名称	简介	举例
1	跨站脚本 Cross Site Scripting,简称为XSS	如果Web应用没有对攻击者的输入进行适当的编码和过滤，就转发给其他用户的浏览器时，可能导致XSS漏洞； 攻击者可利用XSS在其他用户的浏览器中运行恶意脚本，偷窃用户的会话，或是偷偷模拟用户执行非法的操作。	发帖子，发消息
2	注入 Injection Flaws	如果Web应用没有对攻击者的输入进行适当的编码和过滤，就用于构造数据库查询或操作系统命令时，可能导致注入漏洞； 攻击者可利用注入漏洞诱使Web应用执行未预见的命令（即命令SQL注入）或数据库查询（即SQLSQL注入）。	搜索用户
3	文件上传 Malicious File Execution	如果Web应用允许用户上传文件，但对上传文件名未作适当的过滤时，用户可能上载恶意的脚本文件（通常是Web服务器支持的格式，如ASP，PHP等）； 脚本文件在Include子文件时，如果Include路径可以被用户输入影响，那么可能造成实际包含的是黑客指定的恶意代码； 上述两种情况是造成文件上传的最常见原因。	上传附件，上传头像
4	目录遍历 Insecure Direct Object Reference	访问内部资源时，如果访问的路径（对文件而言是路径，对数据库而言是主键）可被攻击者篡改，而系统未作权限控制与检查的话，可能导致攻击者利用此访问其他未预见的资源。	下载文件

OWASP TOP10（续）

No.	漏洞名称	简介	举例
5	跨站请求伪造 Cross Site Request Forgery,简称为CSRF	CSRF攻击即攻击者在用户未察觉的情况下，迫使用户的浏览器发起未预见的请求，其结果往往损害用户本身的利益； CSRF攻击大多利用Web应用的XSS漏洞，也有很多CSRF攻击没有利用XSS而是利用了HTML标签的特性。	不明邮件中隐藏的html链接
6	信息泄露与错误处理不当 Information Leakage and Improper Error Handling	Web应用可能不经意地泄露其配置、服务器版本、数据库查询语句、部署路径等信息，或是泄露用户的隐私。攻击者可利用这些弱点盗窃敏感信息。	错误信息揭示路径
7	认证与会话管理不当 Broken Authentication and Session Management	如果Web应用的认证与会话处理不当，可能被攻击者利用来伪装其他用户身份。	sessionID可猜测
8	存储不安全 Insecure Cryptographic Storge	如果Web应用没有正确加密存储敏感信息，可能被攻击者盗取。 例如攻击者可能通过SQL注入手段获取其他用户的密码，如果Web应用对密码进行了加密，就可以降低此类威胁。	CSDN密码明文保存
9	通讯加密不安全 Insecure Communication	如果Web应用没有对网络通讯中包含的敏感信息进行加密，可能被窃听。	认证信息明文传输
10	URL访问控制不当 Failure to Restrict URL Access	如果Web应用对URL访问控制不当，可能造成用户直接在浏览器中输入URL，访问不该访问的页面。	未授权访问

安全视图



Web安全产品技术演进

技术	起源	工作机制	范围	增强功能（应用安全）
传统网络防火墙	OSI网络模型，提供协议保护	✓网络端口阻断 ✓UDP/TCP状态感知	网络协议	协议执行
传统IPS	提供基于规则的网络保护	✓基于规则的检测 ✓阻断连接 ✓UDP/TCP状态感知	✓网络协议 ✓网络应用	✓增强的访问控制 ✓URL检测 ✓支持众多应用规则
WEB应用防火墙WAF	提供HTTP/HTTPS应用保护	✓URL 标准化 ✓HTTP会话状态感知 ✓应用语境执行	HTTP/HTTPS应用	✓基于语境的正向安全模型 ✓自适应规则（学习能力） ✓内容控制

OWASP Top 10	WAF解决方案
跨站脚本（XSS）	中断连接、验证用户输入，转发之前对进来的请求进行检测
注入缺陷	检测客户端请求，验证输入，阻断恶意的命令
恶意文件执行	阻断异常地、企图访问或请求服务器的OS命令注入
跨站请求伪造（CSRF）	插入随机token到online form中以验证数据流，消除提交恶意请求导致危害的可能
信息泄露和不正确的错误处理	隐藏Web应用架构细节，阻止服务器出错信息发送给用户。过滤及截断服务器侧出的流量，防止敏感信息泄露
失效的验证和会话管理	提供cookie安全机制，避免cookie被篡改，确保会话管理安全
不安全加密存储	过滤及截断服务器侧出的流量，防止敏感信息泄露，如数据库中未加密的用户名及密码
不安全通信	无需更改现有应用，提供SSL加密功能
未能限制URL访问	提供细粒度的URL ACL